

SMART OFFICE 2.0

Politiques de sécurité

Zero Trust · IAM (Entra ID) · Politiques pare-feu (pfSense)

Équipe projet

Sam Flaujat-Ellul | Alexander Kedevil

Formation

Bachelor 3 — Spécialité Infrastructure & Réseaux / Cybersécurité

Établissement

Ynov Campus Montpellier — UF INFRA B3

Juin 2026

Partie I — Zero Trust & Gestion des identités (IAM)

1.1 Principes Zero Trust appliqués

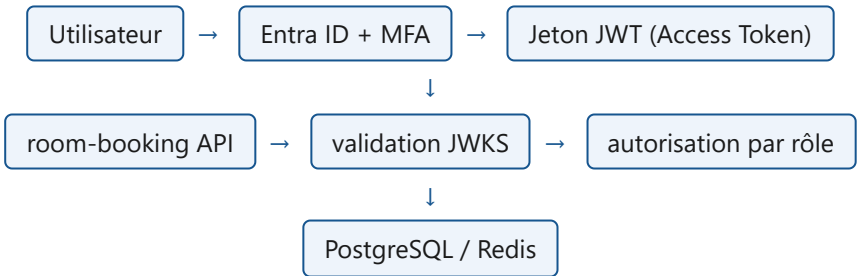
L'approche Zero Trust (ZTA — Zero Trust Architecture, NIST SP 800-207) est le paradigme de sécurité adopté pour Smart Office 2.0. Elle part du principe qu'aucun utilisateur, appareil ou segment réseau ne doit être implicitement considéré comme de confiance, même à l'intérieur du périmètre réseau.

Principe Zero Trust	Mise en œuvre Smart Office 2.0
Never trust, always verify	JWT Entra ID validé sur chaque route API (sauf <code>/health</code>)
Least privilege	Rôles applicatifs Employee et Admin, RBAC Entra ID
Micro-segmentation	6 VLANs pfSense, Wi-Fi invités isolé (VLAN 40)
Assume breach	Logs structurés + monitoring Grafana/Loki, alerting anomalies

Le Zero Trust est particulièrement adapté à un contexte de télétravail flexible (jusqu'à 3 jours/semaine) où le périmètre réseau traditionnel n'a plus de sens. Un employé en VPN accède aux mêmes ressources qu'au bureau — sa session doit être validée à chaque requête, pas seulement à la connexion.

1.2 Architecture IAM — Microsoft Entra ID

L'architecture IAM repose sur Microsoft Entra ID (ex-Azure Active Directory) pour l'authentification et l'autorisation de l'API room-booking :



Entra ID est retenu car il s'intègre nativement avec Azure ACI et évite de développer un système d'authentification maison. Le code flow PKCE (Proof Key for Code Exchange) sécurise l'échange de tokens dans la SPA sans exposer de secret client côté frontend.

1.3 App Registrations Entra ID

App Registration	Rôle
room-booking-api	Expose l'API, définit les scopes et rôles applicatifs (Employee, Admin)
room-booking-client	SPA MSAL — page <code>/login</code> pour obtenir un jeton JWT via code flow PKCE

La séparation en deux App Registrations (API + Client) suit le principe de séparation des responsabilités. L'API expose les scopes ; le client les consomme. Cela permet de révoquer l'accès d'un client sans impacter la définition des permissions de l'API.

Contrainte tenant Ynov : le tenant `ynov.com` n'accorde pas aux étudiants les droits Application Administrator (erreur 401 lors de la registration). Le code IAM est complet ; la démo live Entra nécessite un tenant personnel ou l'intervention du DSI Ynov. En ACI/lab : `AUTH_DISABLED=true` .

`AUTH_DISABLED=true` est une variable d'environnement explicite, jamais codée en dur dans le code source. En production, cette variable est absente : l'IAM est alors actif par défaut. Ce schéma est conforme aux bonnes pratiques (12-Factor App, facteur III : Config).

1.4 Matrice de confiance

Identité	Rôle Entra	Endpoints autorisés
Employé authentifié	Employee	GET/POST bookings, GET rooms, GET availability
Administrateur	Admin	Tout Employee + POST <code>/rooms</code> (création de salle)
Invité Wi-Fi (VLAN 40)	—	Internet uniquement — aucun accès API interne
Développement local	—	<code>AUTH_DISABLED=true</code> (bypass, non production)

L'isolation des invités Wi-Fi (VLAN 40) au niveau réseau est un double verrou : même si un invité tentait d'appeler l'API room-booking, le firewall pfSense bloquerait le flux avant qu'il atteigne l'application. L'IAM est la deuxième barrière, la segmentation réseau est la première.

1.5 Validation technique

- **Bibliothèque :** PyJWT + JWKS Entra (`/discovery/v2.0/keys`)

La validation JWKS (JSON Web Key Set) est la méthode standard : l'API récupère les clés publiques d'Entra ID et les utilise pour vérifier la signature du JWT à chaque requête, sans appel réseau supplémentaire vers Entra ID.

- **En-tête de requête :** `Authorization: Bearer <access_token>`
- **Claims utilisés :** `preferred_username` , `roles`

Utiliser `preferred_username` comme identifiant (plutôt que `sub`) facilite la traçabilité des réservations : l'email de l'employé est lisible directement dans les logs et la BDD, sans jointure avec un annuaire externe.

- **Code source :** `cloud/room-booking/src/auth.py`

1.6 Multi-Factor Authentication (MFA)

MFA activé sur le compte de démonstration Entra ID (configuration via le portail Azure). En production cible : Conditional Access exigeant le MFA pour tout accès à room-booking et pour l'établissement du tunnel VPN WireGuard.

Le MFA réduit de 99,9 % le risque de compromission par credential stuffing (source : Microsoft Security Intelligence Report). Pour une startup biotech avec des données R&D sensibles, c'est un contrôle non négociable. La Conditional Access Policy permet d'exiger le MFA uniquement depuis des réseaux non approuvés, préservant l'expérience utilisateur au bureau.

Partie II — Politiques pare-feu pfSense

2.1 Principes généraux

- **Default deny entre VLANs** : seuls les flux explicitement autorisés passent

Le default deny est la règle fondamentale du principe de moindre privilège appliqué au réseau. Toute nouvelle connexion doit être justifiée et documentée avant d'être autorisée, inversant la logique du default allow des réseaux traditionnels.

- **VLAN INVITES (40)** : accès Internet uniquement, aucun accès LAN

Les invités (visiteurs, prestataires, appareils BYOD) ne peuvent atteindre aucune ressource interne, même en cas de compromission de leur poste. Cette isolation protège les données R&D sensibles contre les vecteurs d'attaque via des appareils non gérés.

- **VLAN MGMT (10)** : accès restreint aux administrateurs réseau

Le VLAN de management est le segment le plus critique : il donne accès en SSH/HTTPS aux switches, APs et au firewall lui-même. Son isolation empêche qu'un poste utilisateur compromis puisse reconfigurer l'infrastructure réseau.

- **VLAN DMZ (60)** : services exposés, flux entrants filtrés

La DMZ isole les services exposés vers Internet (reverse proxy) du réseau interne. En cas de compromission du reverse proxy, l'attaquant ne peut pas rebondir directement vers le VLAN SERVEURS — seuls les ports BDD définis sont ouverts.

2.2 Règles par VLAN

VLAN	Nom	Politique principale
10	MGMT	Accès restreint aux admins — SSH/HTTPS admin depuis VLAN 10 uniquement
20	USERS	HTTPS vers SERVEURS (50), HTTPS vers DMZ (60), Internet autorisé
30	WIFI_STAFF	Même politique que USERS (20) — accès bureau complet
40	WIFI_GUEST	Internet uniquement — isolation totale du LAN (default deny inter-VLAN)
50	SERVEURS	Trafic entrant depuis USERS/WIFI_STAFF uniquement, ports applicatifs définis
60	DMZ	Services exposés — flux entrants filtrés, accès SERVEURS limité aux ports BDD

Le VLAN 40 GUEST est le seul accessible aux appareils non gérés. Si un visiteur connecte un appareil infecté, la propagation est contenue au VLAN 40 sans impact sur les VLANs internes.

2.3 VPN télétravail — WireGuard

Les clients VPN (plage 10.20.100.0/24) bénéficient d'un accès restreint selon la politique suivante :

Accès VPN (10.20.100.0/24)	Destination et justification
VLAN 20 USERS — Autorisé	Postes et imprimantes bureau : nécessaire pour le travail à distance
VLAN 50 SERVEURS — Autorisé	AD, DNS, applications internes : accès légitime pour le télétravailleur
MGMT / GUEST / DMZ — Refusé	Surface d'attaque réduite : un télétravailleur compromis ne peut pas atteindre l'administration réseau

WireGuard est préféré à OpenVPN pour trois raisons : base de code quatre fois plus réduite (meilleure auditabilité), performances supérieures (protocole in-kernel sous Linux), et cryptographie moderne (ChaCha20-Poly1305, Curve25519). L'exclusion du VLAN MGMT du VPN réduit la surface d'attaque en cas de compromission d'un poste télétravailleur.

2.4 Cas particulier de la DMZ

Dans l'implémentation actuelle, la DMZ n'est pas physiquement séparée du reste du LAN : elle est réalisée sous la forme d'un VLAN (60) filtré par pfSense, au même titre que les autres segments. Ce cloisonnement logique, associé à un jeu de règles default deny, isole déjà les services exposés au niveau du pare-feu.

Limite de cette approche : les services accessibles depuis Internet partagent la même infrastructure de commutation que les ressources internes. En cas de compromission d'un service exposé, la séparation ne repose que sur la configuration de pfSense — la surface d'attaque vers le LAN interne reste trop large.

L'architecture cible traite la DMZ comme une zone dédiée aux services exposés, régie par la matrice de flux suivante :

Flux	Politique
Internet → DMZ	Autorisé , limité aux ports publics (HTTPS 443 uniquement)
DMZ → SERVEURS (50)	Restreint aux seuls ports applicatifs nécessaires (ex. BDD)
DMZ → LAN interne	Interdit
LAN interne → DMZ	Autorisé (administration, publication de contenu)

Le principe directeur est qu'aucune connexion ne doit pouvoir être initiée depuis la DMZ vers le réseau interne : un service exposé compromis reste ainsi confiné à sa zone. La mise en œuvre de cette cible est détaillée en Partie III.

Partie III — Évolution : vers une DMZ isolée

3.1 Rôle de la DMZ

La DMZ héberge tout composant qui doit être joignable depuis l'extérieur du réseau du siège, sans jamais donner d'accès direct au LAN interne. Dans le périmètre du projet, elle accueillerait :

- **un reverse proxy** (nginx ou HAProxy) en frontal de l'application de réservation de salles, terminant le TLS et relayant les requêtes vers le back-end ;
- **le point de publication du service métier** (room-booking) lorsqu'il est hébergé on-premise plutôt que sur Azure ;
- à terme, tout service exposé complémentaire (portail de messagerie, passerelle applicative, serveur de fichiers externe).

Les bases de données et les données sensibles (R&D, PostgreSQL) restent dans le VLAN SERVEURS (50), jamais dans la DMZ : seul le reverse proxy y accède, et uniquement sur le port applicatif requis.

3.2 Mise en œuvre sur pfSense

- 1. **Interface dédiée** — affecter le VLAN 60 (em1.60 , 10.20.60.0/24) à une interface **DMZ** distincte, idéalement portée par un port physique ou un trunk séparé du LAN de production
- 2. **NAT entrant (port forward)** — sur l'interface WAN, rediriger le trafic TCP/443 vers l'adresse du reverse proxy en DMZ (ex. 10.20.60.10:443) ; pfSense crée automatiquement la règle de pare-feu associée
- 3. **Règles sortantes de la DMZ** — autoriser explicitement le seul flux DMZ → 10.20.50.x sur le port applicatif du back-end, puis un block général vers LAN net , MGMT net et les autres VLANs internes (default deny)
- 4. **Filtrage des flux internes → DMZ** — n'ouvrir depuis USERS (20) et MGMT (10) que les ports d'administration et de publication nécessaires
- 5. **Journalisation** — activer les logs sur les règles DMZ et les faire remonter vers la chaîne de supervision (syslog pfSense → Loki), afin de détecter toute tentative de connexion anormale depuis la zone exposée

3.3 Niveaux de maturité d'une DMZ

Une DMZ peut être réalisée selon plusieurs modèles, du plus simple au plus robuste :

Niveau	Modèle	Principe	Limite
1	DMZ-VLAN	Segment (VLAN 60) filtré par le pare-feu, sur la même infrastructure que le LAN. Séparation purement logique.	La frontière ne repose que sur la configuration du pare-feu.
2	DMZ « three-legged » → choix retenu	Interface physique dédiée sur pfSense (WAN / LAN / DMZ). Le trafic DMZ ↔ LAN traverse obligatoirement le pare-feu.	Un seul pare-feu : sa compromission expose tout.
3	DMZ « back-to-back » (screened subnet)	Deux pare-feux encadrent la DMZ, idéalement de marques différentes.	Coût et complexité (deux équipements à administrer).



Choix retenu : le niveau 2 (three-legged) constitue la cible de ce projet. Il fournit une isolation réelle — le trafic entre la DMZ et le LAN est contraint de traverser le pare-feu — tout en restant réaliste à déployer avec un unique pfSense en lab. Le niveau 3, référence en grande entreprise, est mentionné comme évolution possible : il apporte une défense en profondeur (deux pare-feux distincts) au prix d'une complexité et d'un coût supérieurs, non justifiés à l'échelle du siège considéré.

Statut : en PoC, la publication du service métier est assurée par l'hébergement cloud (Azure ACI), qui remplit le rôle d'isolation vis-à-vis du réseau du siège. La DMZ isolée décrite ici constitue l'équivalent on-premise, retenu comme cible pour un déploiement interne en production.